Access Governance & Data Handling Policy

The CNP platform processes and stores data for the following USDA federal nutrition programs: National School Lunch Program (NSLP), School Breakfast Program (SBP), Child and Adult Care Food Program (CACFP), Summer Food Service Program (SFSP), Fresh Fruit and Vegetable Program (FFVP), and Community Eligibility Provision (CEP).

The data includes:

- **Child eligibility determinations**: free/reduced/paid status based on household income, participation in SNAP, TANF, FDPIR, or Medicaid. This is sensitive household income data for families with school-age children.
- **Direct Certification records**: matches against SNAP, TANF, and Medicaid enrollment rolls. Includes child name, school, and program participation.
- **National Disqualified List (NDL) matches**: records of individuals disqualified from program participation due to fraud or program abuse findings.
- **Sponsor and site financial records**: federal reimbursement claims, fiscal actions, administrative budgets.

This data is subject to FERPA (Family Educational Rights and Privacy Act) when held by a school or school district, and to state-level privacy regulations across 28 states. It is also subject to federal program integrity requirements.

Applicable regulatory frameworks

NIST SP 800-171 (CUI)

Child nutrition eligibility data qualifies as Controlled Unclassified Information (CUI) under the NIST framework when it is created or handled in connection with a federal program. NIST SP 800-171 establishes 110 security requirements across 14 control families. LINQ must maintain compliance with 800-171 for all systems that process, store, or transmit CNP data, including development and staging environments that use realistic data.

Key obligations: Access control, audit and accountability, configuration management, identification and authentication, incident response, media protection, personnel security, risk assessment, system and communications protection.

FERPA

When LINQ processes eligibility data on behalf of a school district or state educational agency, LINQ is a "school official" under FERPA in the context of that relationship. This means: no

disclosure of education records to third parties without consent, strict access controls, and breach notification requirements. LINQ's data processing agreements (DPAs) with state agencies must explicitly address FERPA obligations.

State-specific requirements

Each states has its own data privacy and data breach notification laws. The most restrictive in the current state set (AK, HI, ME, MO, UT, WI for DIS; 22+ CTS states) apply minimum 72-hour breach notification windows. Any incident involving PII from these states triggers the notification obligation under the most restrictive applicable state law — typically California standards if CA is in scope, otherwise state-by-state analysis.

Current status: State-specific DPA review is a pending item. Legal must confirm DPA coverage for all 28 states before production data is processed on the new platform.

Access control matrix

Role	Production data	Staging data	Dev data	Production credentials	Schema migrations
LINQ US onshore engineer	Read-only via break-glass	Full access	Full access	None	Via CI/CD pipeline only
LINQ onshore config admin	Config writes via API	Full access	Full access	None	No
Offshore engineer (build team)	None — ever	Synthetic data only	Synthetic data only	None — ever	No
State agency administrator	Own state only, via app	None	None	None	No
FNS Auditor	Read-only, specific states, via app	None	None	None	No
LINQ DBA (US-based)	Read-only by default; break-glass write	Full access	Full access	Via secrets manager only	Via CI/CD pipeline only

"Break-glass" write: the engineer submits a request through the access management system, provides a business justification, access is granted for a time-limited session. This process applies to onshore engineers and DBAs. It is never available to offshore contractors.

Offshore contractor policy

The CNP platform uses an offshore-builds / onshore-configures model. Offshore engineers build the engine; onshore staff configure per-state behavior. This section establishes the absolute boundaries for offshore access.

Hard rules

- Offshore engineers have zero access to production environments. This includes production databases, production AWS accounts, production Secrets Manager, and any system that processes or stores real child nutrition data.
- Offshore engineers have zero access to production credentials. This is enforced by the `ISecretProvider` architecture — production secrets exist only in the production secrets store, which offshore roles cannot access. This is structural, not policy-only.
- Staging environments accessible to offshore engineers contain only synthetic data.
- All PRs that touch compliance logic (named hooks, IsFederal configuration, audit trail, federal math) require review and approval by a US-based onshore engineer before merge. Offshore engineers cannot self-approve compliance PRs.
- Offshore engineers may not export data from any LINQ environment. Data exfiltration controls (DLP) must be active on all environments accessible to offshore teams.
- Offshore engineers working on AI/ML components (compliance risk scoring, NLP query interface) work only against synthetic training data. Real claim and application data used for model training must be processed by US-based staff only, in a US-based secure environment.

Contractor vetting requirements

- All offshore contractors must sign a data handling agreement before receiving any system access. The agreement must reference NIST SP 800-171 obligations and FERPA.
- Offshore access is provisioned per-individual, not per-team. Shared accounts are prohibited.
- Access is revoked within 24 hours of a contractor's engagement ending. Access management must be notified by the engagement manager, not by the contractor's departure alone.
- Offshore teams handling any portion of the platform that touches federal compliance logic must be identified to the LINQ security team. This requirement applies to subcontractors of subcontractors.

Test data requirements

No real child nutrition data — eligibility records, household income data, DC match records, NDL records — may be used in development or staging environments. This is an absolute rule regardless of whether the data appears "anonymized" through column masking alone. Column masking is insufficient — re-identification risk is high for small-population states (AK, HI, ME).

Test data approaches

- **Synthetic generation**: Generate realistic but entirely fabricated eligibility data using a data generation tool. Preserve statistical distributions from real data (e.g., free/reduced/paid ratios by program type) without using any real records.
- **Production replay in isolated environment**: For the CTS/DIS replay validation process (Testing Strategy, Section 5), real data may be used in a dedicated isolated validation environment with onshore-only access. This environment is not a "staging environment" for development purposes.

Production credential access

Production credentials (database passwords, API keys, SFTP credentials for DC feed providers, AWS access keys for production accounts) are managed exclusively through the `ISecretProvider` interface and stored in the production secrets store. The naming convention is `cnp/prod/{tenant-or-global}/{category}/{name}`.

- Production credentials are never stored in source code, configuration files, container images, environment variables outside the secrets store, or application databases. This is enforced by the CNP_Secrets_Management design and by code review.
- Rotation: production credentials rotate on a schedule (database passwords: 90 days; API keys: 180 days; SFTP credentials: per state agency agreement). Rotation is automated via the secrets manager — no manual rotation.
- Emergency rotation: if a credential is believed compromised, rotation is immediate. The incident response process (Section 8) is initiated simultaneously.
- Audit: every secrets manager access is logged. Unusual access patterns (access outside business hours, access by unexpected principals) trigger a security alert.

Code review requirements for compliance logic

Not all code changes carry equal compliance risk. The following categories of changes require elevated review:

Change Type	Review Requirement
New named hook (condition or action)	Onshore engineer review + IsFederal classification confirmed. New guardrail assertion test required in same PR.
New ConfigDefinitions row with `IsFederal=true`	Onshore engineer review + federal citation confirmed against current regulation. Guardrail assertion test required.
Changes to federal math logic (CEP, CACFP tier, SFSP rate)	Two-person review: one onshore engineer + one domain expert (compliance team or state agency contact). FNS regulatory reference required in PR description.
Changes to audit trail logic (AuditLogs, EntitySnapshots, FieldChangeLog)	Onshore engineer review. Any reduction in audit coverage requires explicit justification.
Database migrations that touch override tables or reference tables	Onshore engineer review. Trigger integrity must be verified post-migration.
Changes to `ISecretProvider` implementations	Onshore engineer review. No production credential values may appear in the diff.

Incident response

An incident is any event involving actual or suspected unauthorized access to, disclosure of, or loss of CNP data. This includes: unauthorized access by an offshore contractor, a data breach, a break-glass access session that produces anomalous activity, and any system behavior that may have disclosed one state's data to another state's users.

Immediate response (within 1 hour of detection)

- Contain: revoke the access or isolate the system component involved.
- Preserve: do not delete logs or rotate credentials until forensics is complete.
- Notify: LINQ security lead + VP of Engineering within 1 hour. Legal notified within 4 hours.

Reporting obligations

- State agency notification: within 24 hours of confirmed breach affecting their data, regardless of state law deadline (state law deadlines are a minimum floor, not a target).

- USDA FNS notification: consult with Legal. FNS notification may be required depending on whether the breach affects program integrity.
- State breach notification laws: Legal must determine the applicable deadline for each state whose residents' data may be involved. The most common window is 30-72 hours; some states require 30 days.

Disaster recovery posture

This is completely fabricated. Need to discuss with Ed.

The DR plan for CNP production is currently under assessment. The following are design requirements, not confirmed implementations. DR posture must be confirmed and tested before any state goes live on the new platform.

Target DR requirements:

- **RPO (Recovery Point Objective)**: 1 hour. No more than 1 hour of claim or application data may be lost in a disaster event.
- **RTO (Recovery Time Objective)**: 4 hours. The platform must be operational within 4 hours of a declared disaster.
- **Backup**: Aurora automated backups with point-in-time recovery (35-day retention). Daily snapshots retained for 1 year. Backups are cross-region (primary: us-east-1, secondary: us-west-2).
- **DR test**: Full DR restore test must be completed before first state go-live and annually thereafter. Test results must be documented.
- **SFSP seasonal consideration**: Any DR event during May–August affecting SFSP states must prioritize SFSP data recovery given active summer service operations.

What "still being assessed" means for current planning: No state can go live on the new platform until DR posture is confirmed, tested, and documented. This is a hard gate, not a soft recommendation. A production system handling federal child nutrition data with no confirmed DR plan is not compliant with NIST SP 800-171 control families CP (Contingency Planning) and IR (Incident Response).

Open items and owners

Item	Status	Owner	Required before
State DPA review for all 28 states	Pending	Legal	First state production go-live

Offshore contractor data handling agreement template	Pending	Legal + Engineering lead	Before offshore access provisioned
Offshore contractor registry (current engagements)	Pending	Engagement manager	Immediately
Synthetic test data generation pipeline	Not started	Engineering	Before offshore team begins development
Break-glass access management system	Not started	DevOps / Security	Before production environment provisioned
DR plan finalization and test	Under assessment	DevOps / Engineering lead	First state production go-live
NIST SP 800-171 gap assessment	Not started	Security lead	Before production environment provisioned
Offshore DLP controls deployment	Not started	Security / DevOps	Before offshore team receives any environment access